

Communications and Cybersecurity

Topic 2 – Security in OSI Layers & Historical perspective of cryptography

Outline

- Layers (recalling OSI & TPC/IP models)
- (brief) Introduction to cryptography
- Cryptography a (brief) Historical perspective
- Transport Layer Security

Outline

- Layers (recalling OSI & TPC/IP models)
- (brief) Introduction to cryptography
- Cryptography a (brief) Historical perspective
- Transport Layer Security

Layers

OSI Model

Layer	Description
7 - Application	Services, end user applications
6 - Presentation	Data formats, encryption, compression
5 - Session	Handles sessions
4 - Transport	Reliable data transport
3 - Network	Path for data, logical addressing, routing
2 – Data Link	Physical addressing (MAC), error detection
1 - Physical	Transmission over the medium (bitstreams)

TCP/IP model

Layer	Description
4 - Application	Services, end user applications
3 - Transport	Data transport (TCP, UDP)
2 - Internet	Path for data, logical addressing, routing (IP)
1 – Network access	Physical addressing (MAC), error detection Transmission over the medium (bitstreams)

Layers focusing on TCP/IP model

Which layer should we secure ?

Layer	Protocols/Standards	Security Solutions
4 - Application	HTTP, FTP, SMTP, POP, DNS, DHCP, SSH, SNMP	HTTPS – Secure HTTP
3 - Transport	TCP, UDP, SCTP, QUIC, ...	TLS – Transport Layer Security
2 - Internet	IPv4, ARP, IPv6, ICMP	IPSEC – IP Security VPN – Virtual Private Network
1 – Network access	Ethernet, WiFi, PPP, 5G NR	Security mechanisms (e.g., 802.11X)

Security in the TCP/IP model layers

Which layer should we secure ? → **ALL**

But should we secure them all at the same time ?

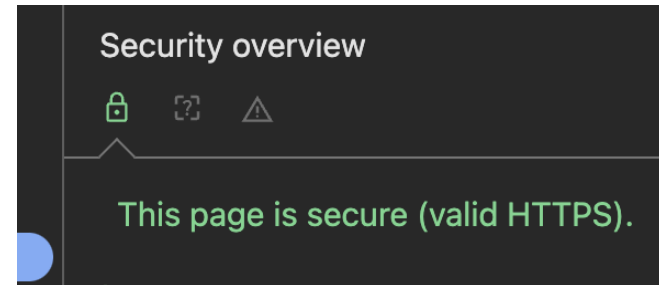
- It depends on the use case

Layer	
4 - Application	
3 - Transport	
2 - Internet	
1 – Network access	

Security in the TCP/IP model layers - Instagram

In the Instagram case

- We use HTTPS
- Which requires support from TLS



Network access may also be secured

Layer	Protocols	
4 - Application	HTTP (HTTPS)	
3 - Transport	TLS	
2 - Internet		
1 – Network access		

Security in the TCP/IP model layers - Organization

In an organization case

- We might use HTTPS with support of TLS
- We might need specific security through Virtual Private Networks (VPN)
- Network access may also be secured

Layer	Protocols	
4 - Application	HTTP (HTTPS)	
3 - Transport	TLS	
2 - Internet		
1 – Network access		

Security in the TCP/IP model layers - Organization

VPN to the infrastructure of DEI

From home
you can access
the same resources
as if you were
physically at DEI

DEI Helpdesk

Home
About SIC
General Information
Download Software

My Helpdesk

Configuration Instructions

Accessing your UNIX server

Add the DEI Certification Authority

BYOD
Videoconference (VaddioStation)

Changing your password

Configuring 2-Step Authentication on



VPN access

VPN Overview

Virtual Private Network (VPN) creates a secure connection, called a tunnel, between your computer and the DEI campus. This tunnel allows secure communications and the ability to extend local network access to offsite locations.

When do I need a VPN connection?

- If you are off-site and need to access a service that is restricted by IP address (e.g., www.springerlink.com).
- If you are accessing a service which exists only on a restricted subnet.

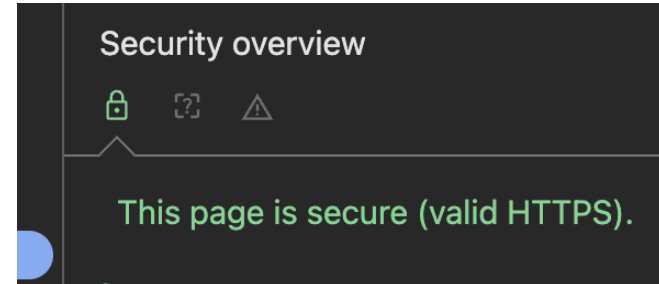
Cannot connect in Windows?



Coming back to Instagram

In the Instagram case

- We use HTTPS
- Which requires support from TLS



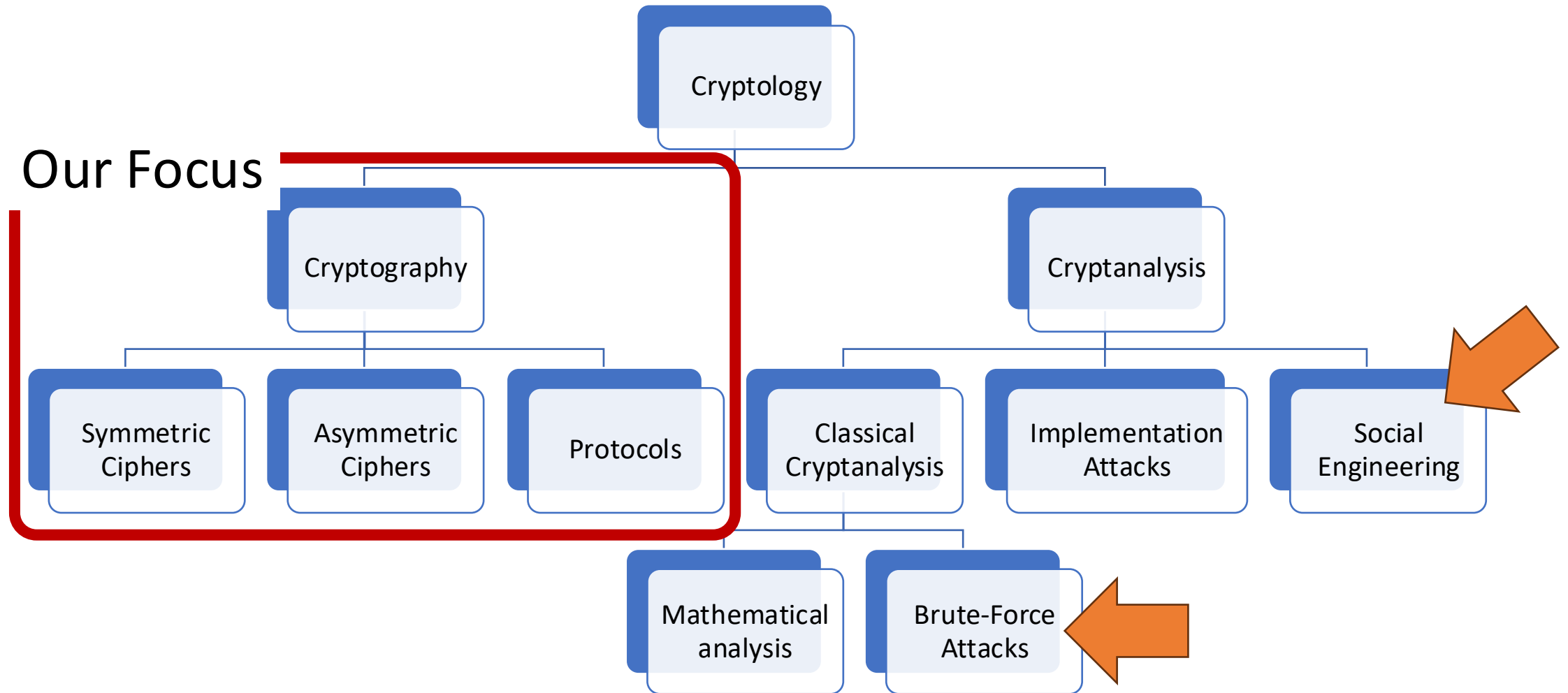
Network access may also be secured

Does it make sense to have VPN to access Instagram?

Outline

- Layers (recalling OSI & TPC/IP models)
- **(brief) Introduction to cryptography**
- Cryptography a (brief) Historical perspective

Context for cryptography

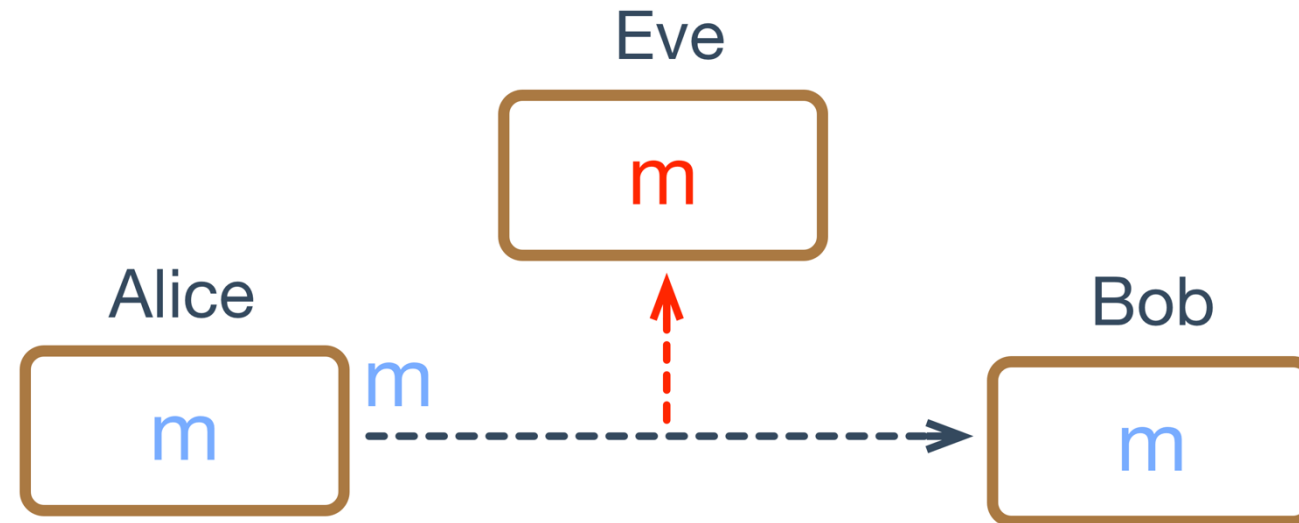


Cryptography Concepts

- **Cryptography** – science of securing communication against adversary;
- **Cryptoanalysis** – science /art of braking cryptosystems;
- **Symmetric Ciphers** – based on the same secret key
- **Asymmetric Ciphers** – based on the same public key, uses two keys: one public and a private key
- **Protocols** - perform complex security functions using encryption algorithms. Example of Transport Layer Security (TLS)

Cryptography Concepts

- Sample use: **Confidentiality** (CIA)
 - How can Alice and Bob communicate securely?



Cryptography Concepts

- m – plain text message
- Gen - key generation algorithm
- k – key
- E – encryption algorithm
- c – encrypted message
- D – decryption algorithm

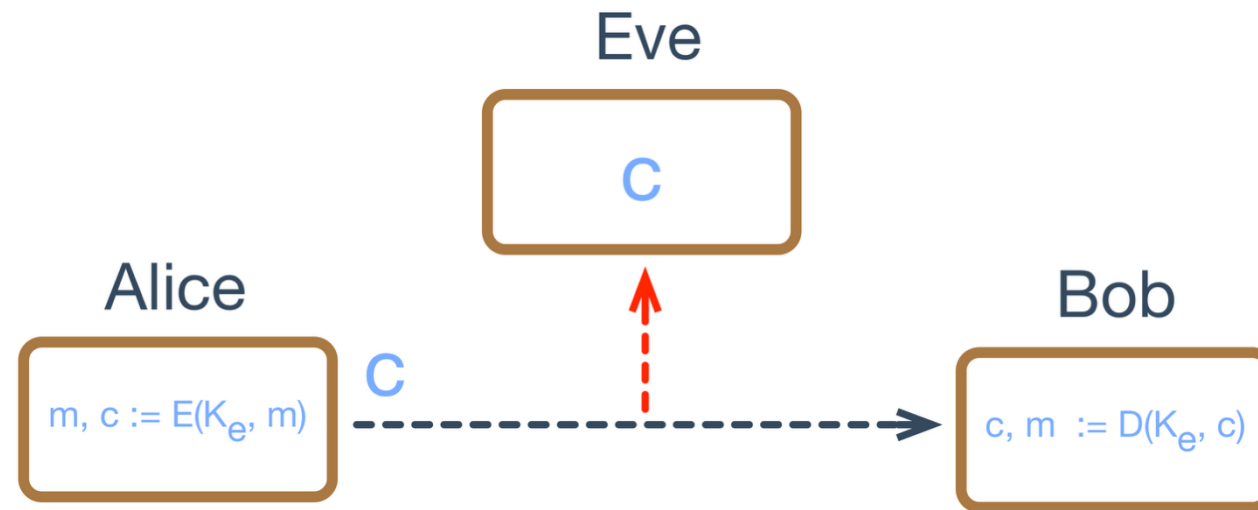
$$c = E(k, m)$$

$$m = D(k, c)$$

$$D(k, E(k, m)) = m$$

Cryptography Concepts

- Generic setting for confidentiality

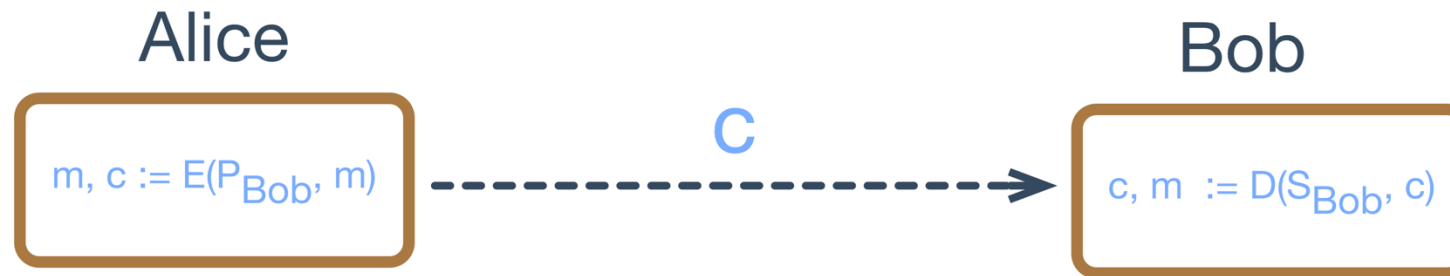


Public key encryption

- Each user has two keys
 - A public key, that can be known to everyone
 - A secret key, only known by its owner
- A message encrypted with one of the keys in the pair can only be decrypted with the other key
- This simplifies the problem of key distribution
 - Only the public key is distributed and there is no need for secrecy

Public key encryption

- Generic setting for public key encryption



Public key encryption

- Public key encryption is much less efficient than secret key encryption.

Any idea why?

- Typically, a combination of both types of encryption is used in practical systems
 - Public key encryption – used to establish and exchange a secret key
 - The secret key is then used for encrypting the actual data

Digital Signatures

- Public key equivalent of message authentication codes



Outline

- Layers (recalling OSI & TPC/IP models)
- (brief) Introduction to cryptography
- **Cryptography a (brief) Historical perspective**
- Transport Layer Security

Historical perspective

- Caesar's cipher
 - Shift the letters of the alphabet 3 places forward
 - **begintheattacknow → EHJLQWKHDWWDFNQRZ**
 - No key: if you know the algorithm you decrypt the message
- Variation: shift cipher
 - The key is the number of places to shift ($0 < k < 25$)
 - $E_k(m_1..m_l) = c_1...c_l$, where $c_i = [(m_i + k) \bmod 26]$
 - Still too easy to break by brute force attack, as there are only 26 possible keys
 - Lesson: key space must be sufficiently large ($> 2^{70}$)

Historical perspective

- Mono-alphabetic substitution cipher
 - Each alphabet letter is mapped one-to-one to another arbitrary alphabet letter (e.g., a to M, b to D, c to W, etc)
 - Key space size: $26! = 26 \times 25 \times 24 \times \dots \times 2 \times 1 = 288 \gg 270$
 - Brute force attack infeasible, but still not secure. Why?
 - Can be attacked by utilizing statistical patterns of the language

Historical perspective

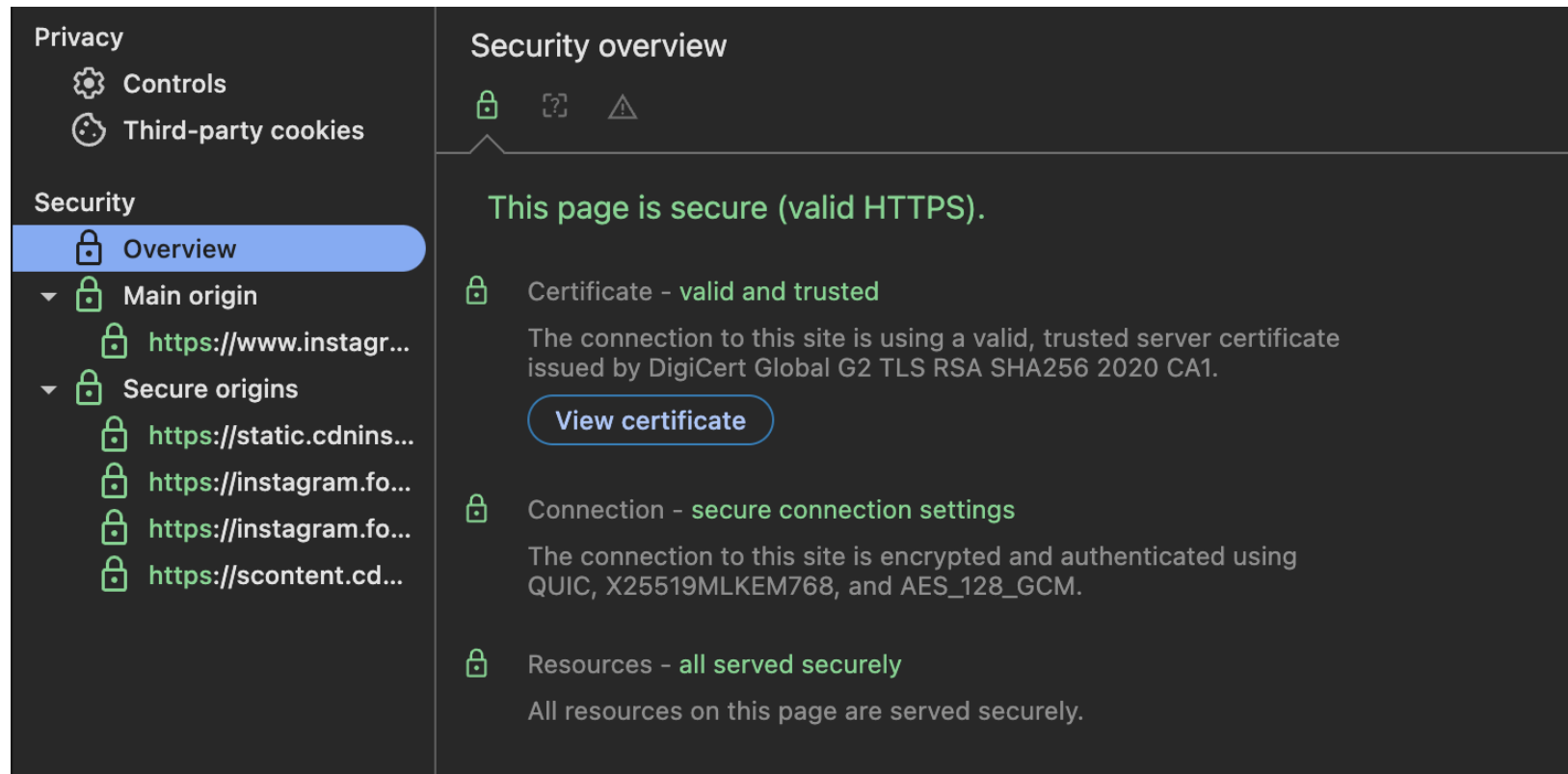
- World War II – The Enigma machine
 - Combination of mechanical and electronic systems
 - Used a symmetric key algorithm (same key for encrypting and decrypting)
 - Used rotors, a daily key and wire settings to determine the used key
 - Several versions in the Enigma series
 - Invented and used by the Germans for communication with their U-boat fleet
 - Using electronic computers, thousands of hours, many scientists (including Alan Turing) and a bit of luck, the Allies managed to crack it

Outline

- Layers (recalling OSI & TPC/IP models)
- (brief) Introduction to cryptography
- Cryptography a (brief) Historical perspective
- **Transport Layer Security**

Security Communications – More Instagram details

- Example of Instagram



Security Communications – At TCP/IP layers

Application Layer	S/MIME, SMTP, HTTP, DNS, ...
Transport Layer	TLS (Transport Layer Security), QUIC
Network Layer	IPSec, VPN

- Application Layer, protects a specific service.
- The Transport Layer (TLS) provides a common layer of protection for applications/services.
- The network layer provides an extra layer of protection, giving the possibility to protect information of IP addresses.

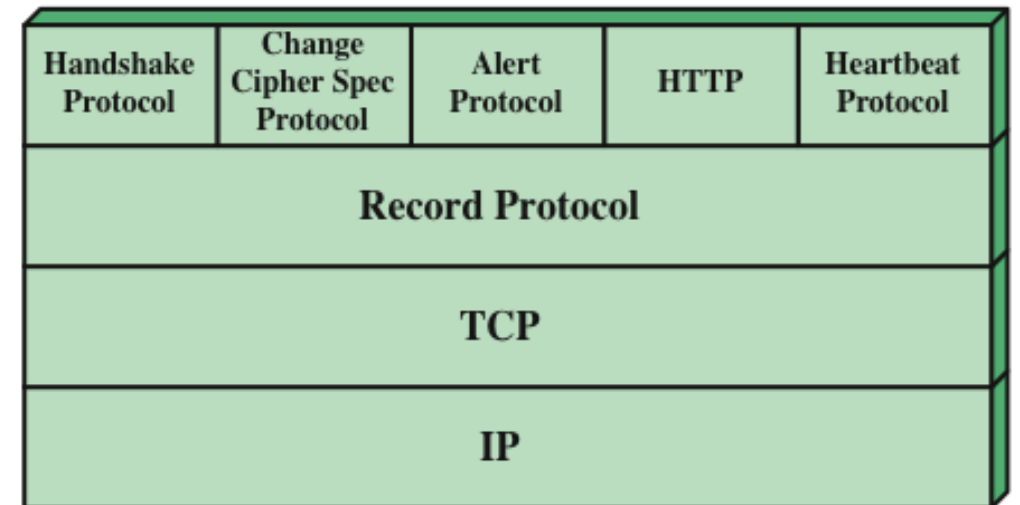
Security Communications – TLS

Transport Layer Security

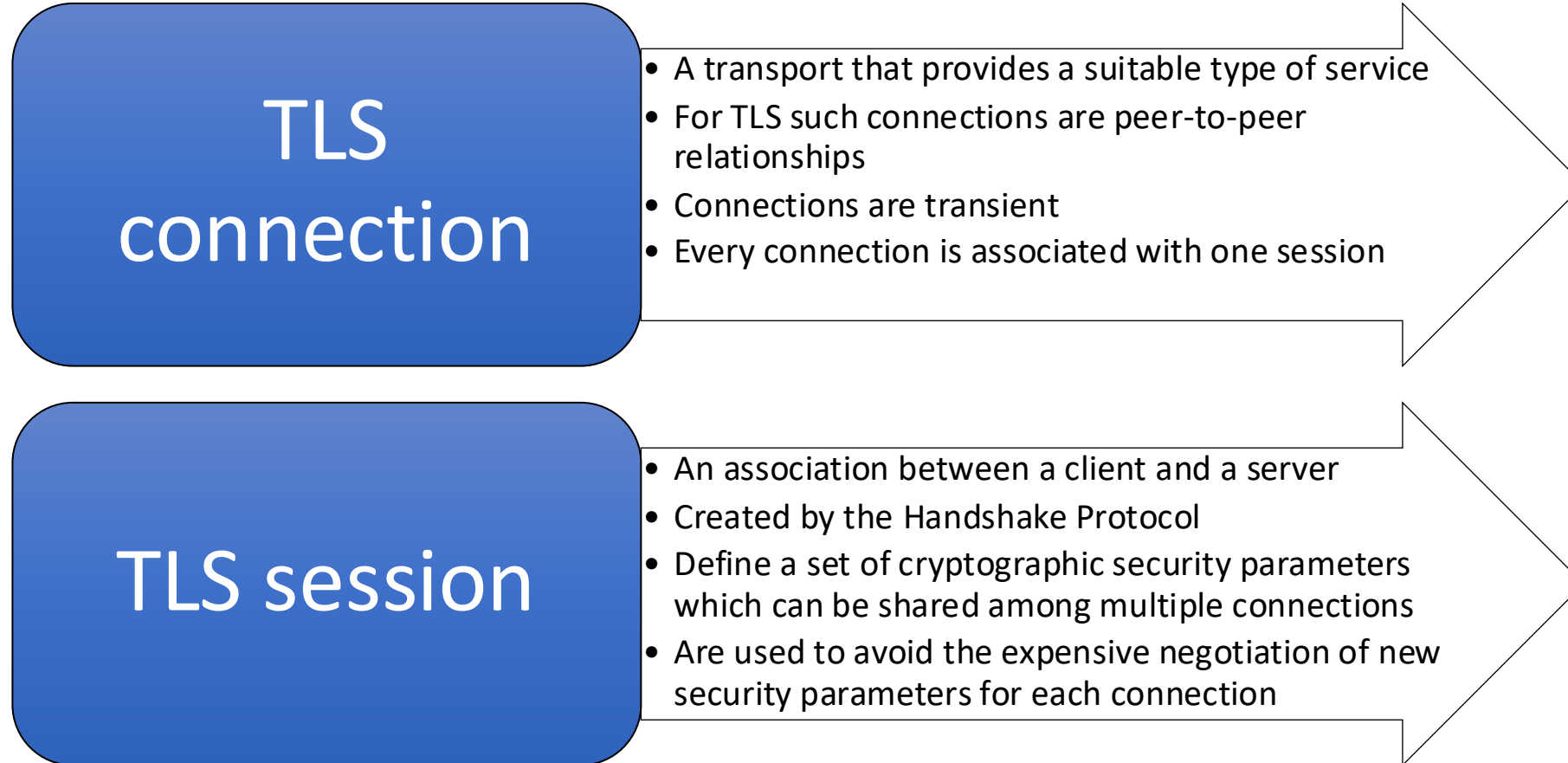
- TLS is not a single protocol, but rather two layers of protocols:

A. The TLS Record Protocol provides basic security services to various higher layer protocols, in particular, the Hypertext Transfer Protocol (HTTP)

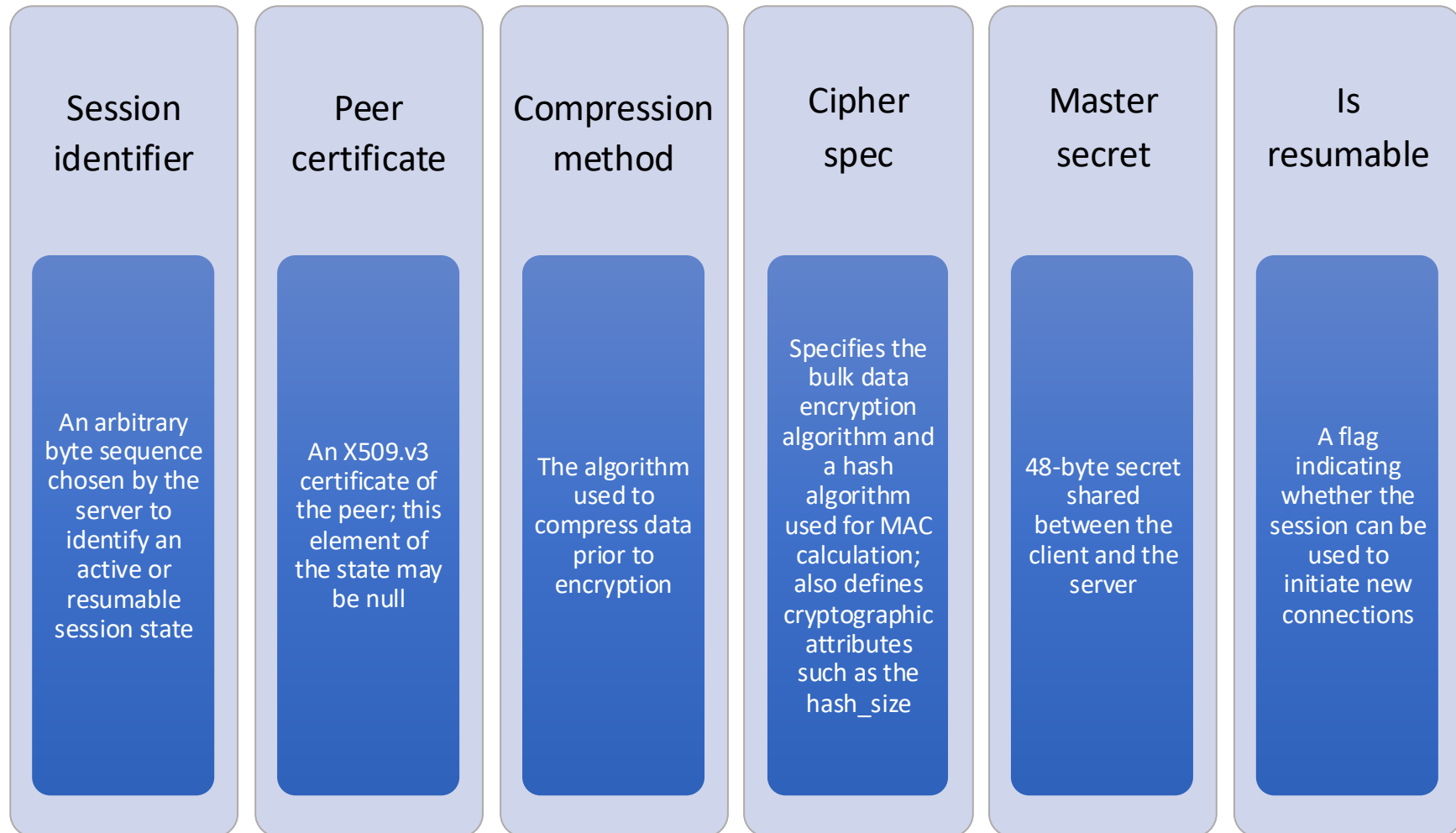
B. Three higher-layer protocols are defined as part of TLS: the Handshake Protocol, the Change Cipher Spec Protocol, and the Alert Protocol. These TLS specific protocols are used in the management of TLS exchanges



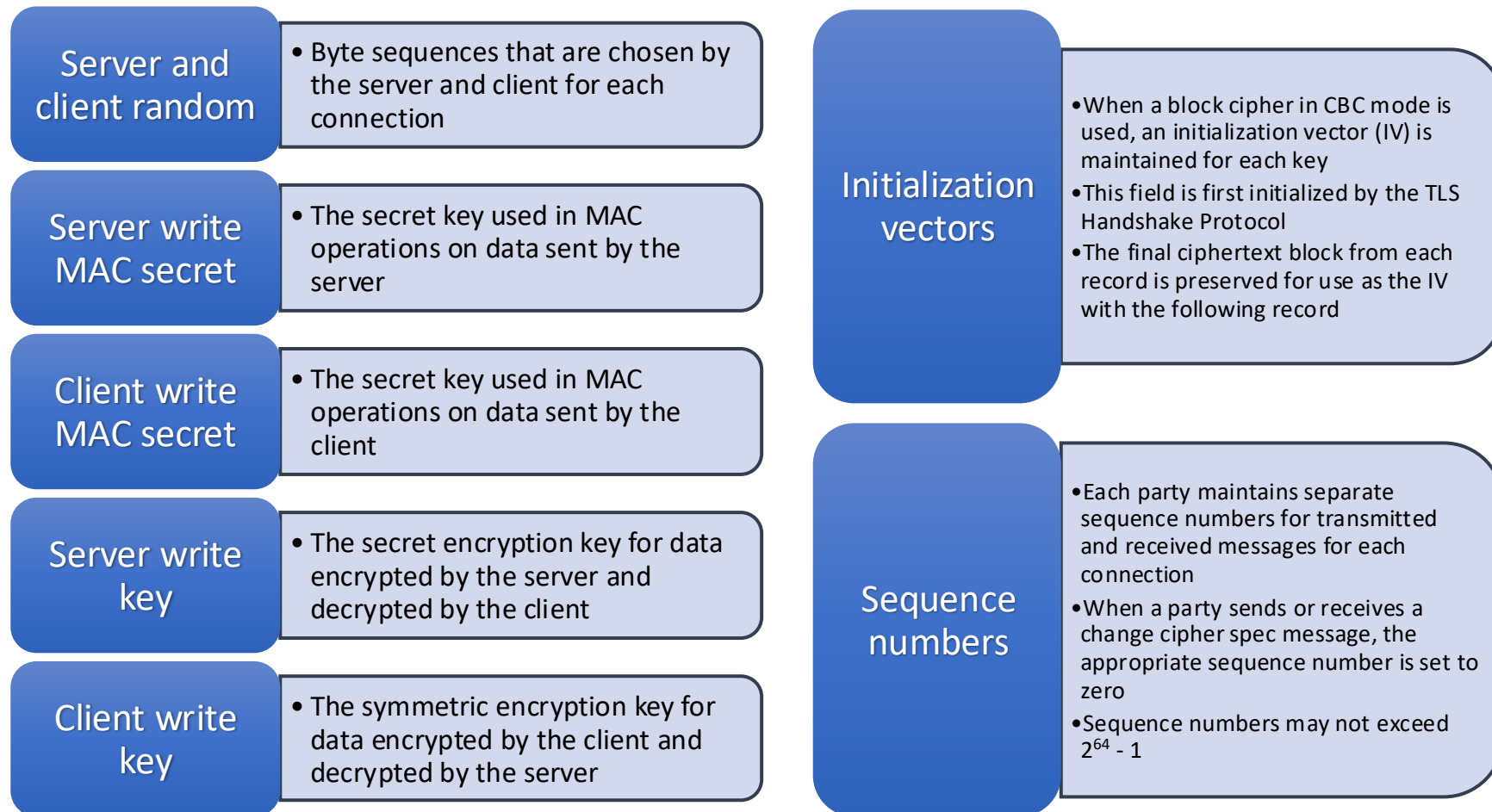
Security Communications – TLS Architecture



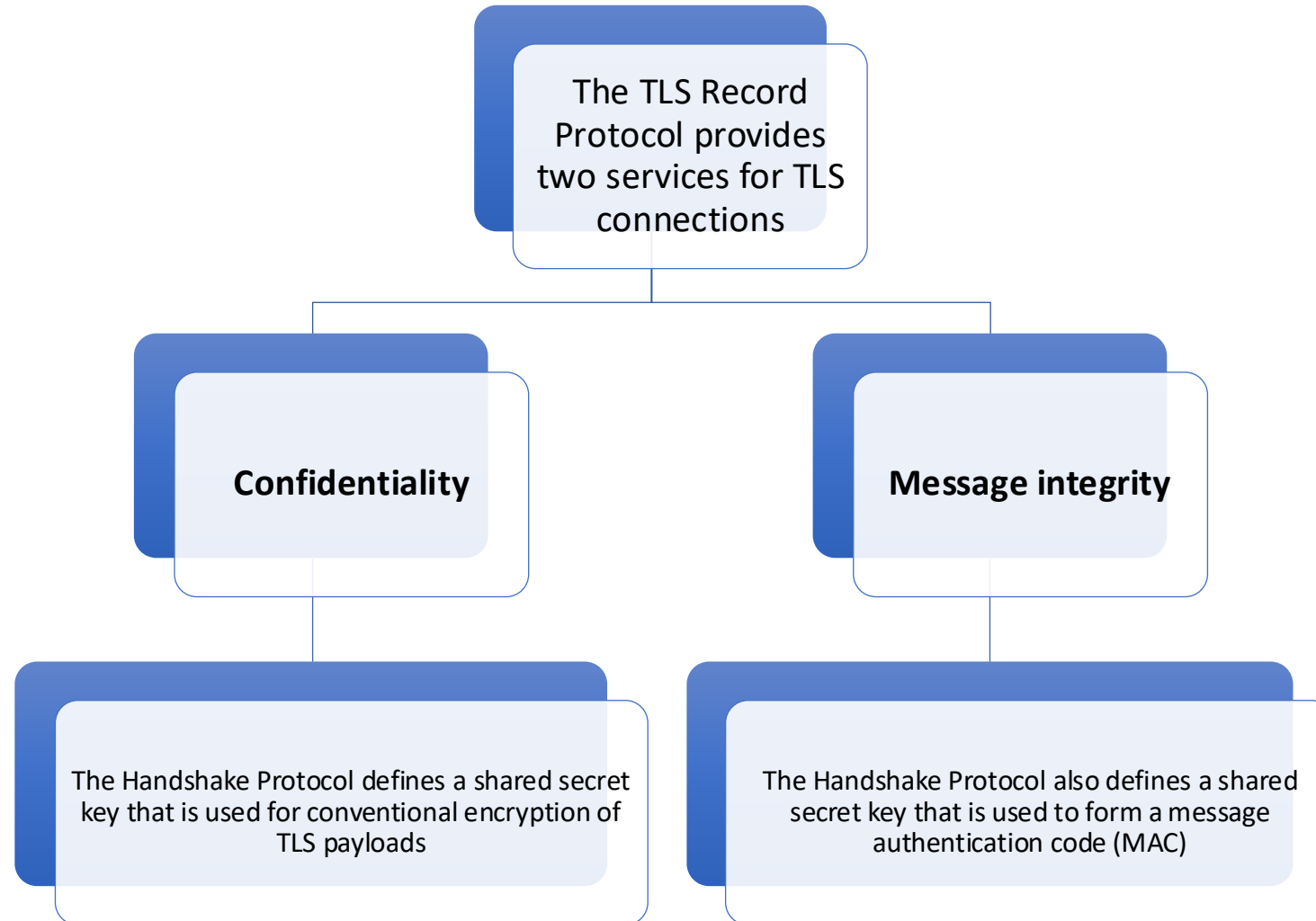
Security Communications – TLS Session State



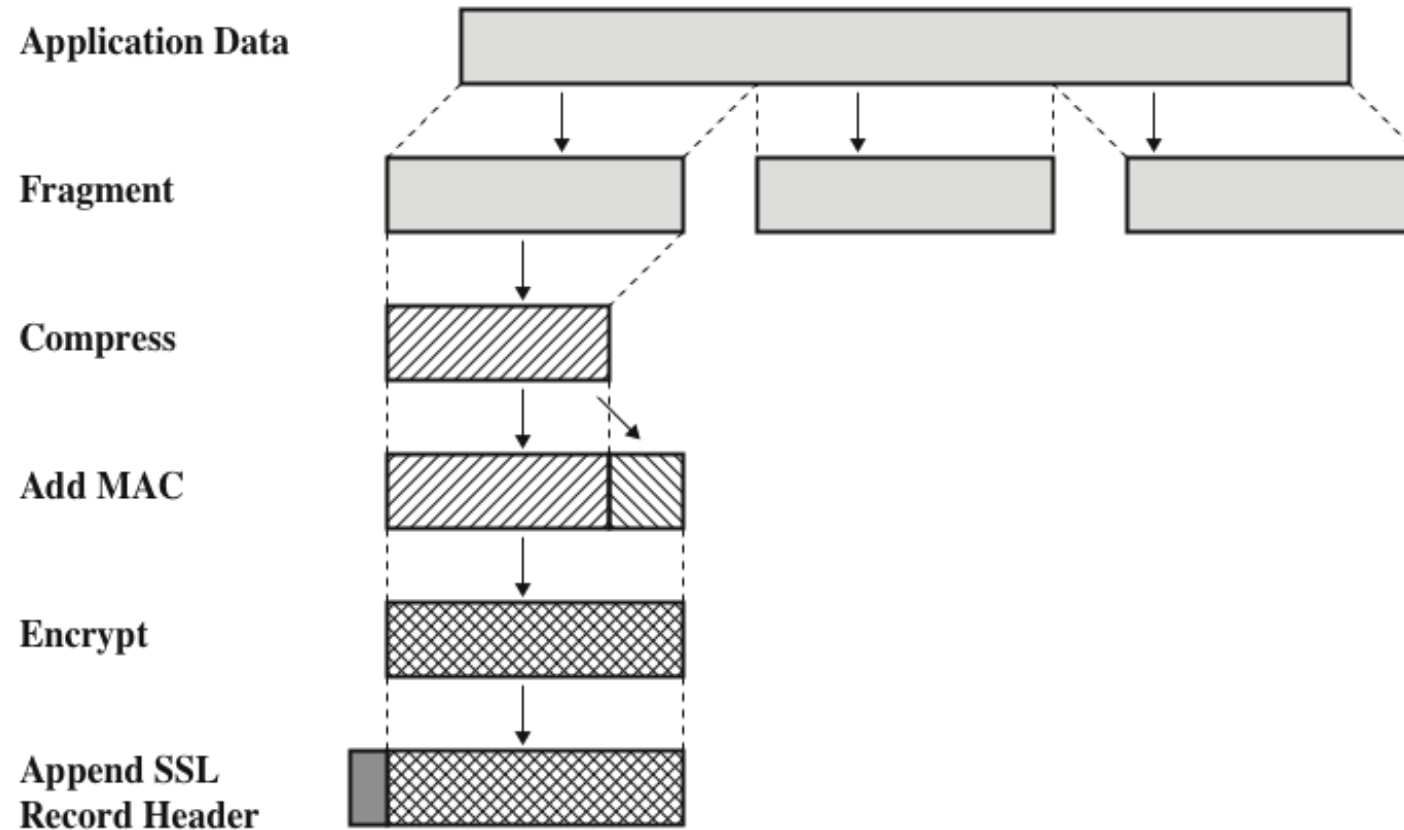
Security Communications – TLS Connection State



Security Communications – TLS Record Protocol



Security Communications – TLS Record Protocol



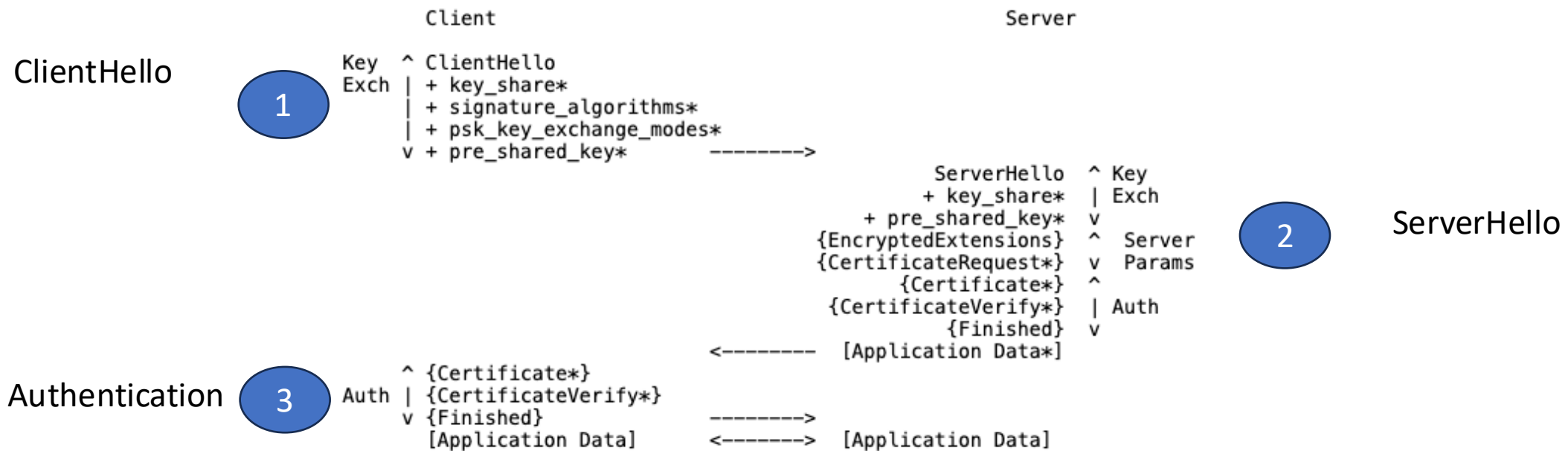
Security Communications – TLS Handshake Protocol

Responsible to negotiate the security parameters of a connection ([RFC8446](#)):

- Key exchange → security capabilities of the client and the server and to establish shared secrets
- Negotiation of extensions
- Share server parameters
- Authenticate message

Security Communications – TLS Handshake

TLS v1.3 Handshake in three phases ([RFC8446](https://tools.ietf.org/html/rfc8446)):

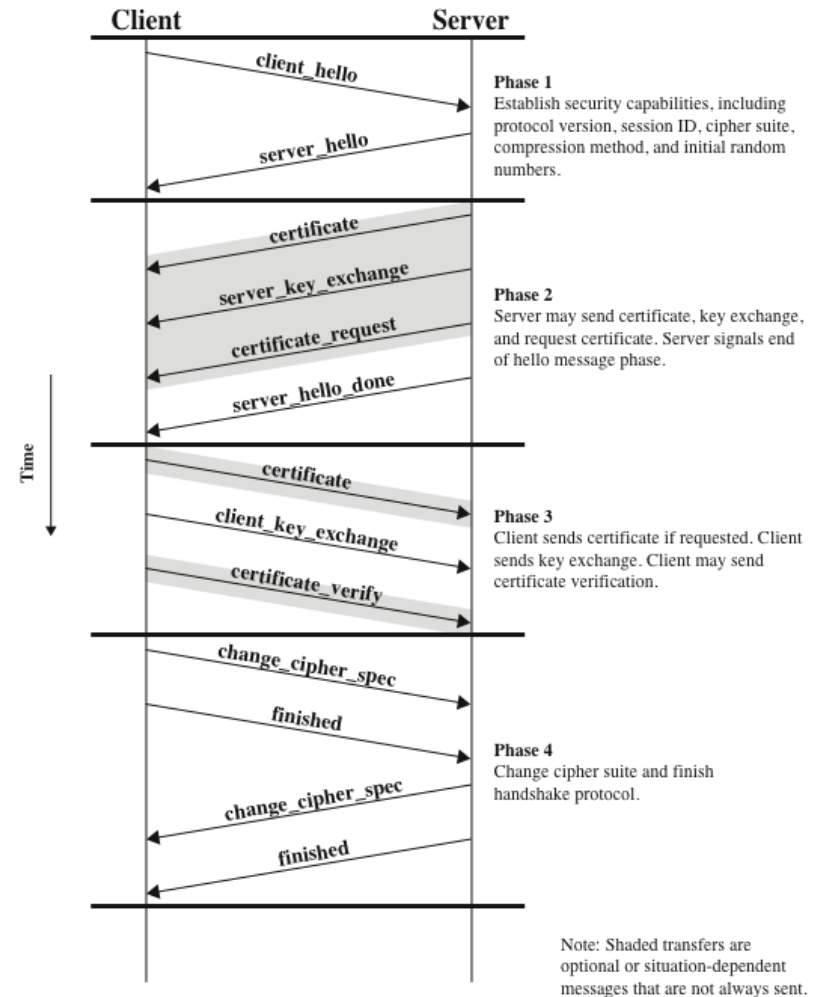


- + Indicates noteworthy extensions sent in the previously noted message.
- * Indicates optional or situation-dependent messages/extensions that are not always sent.
- { } Indicates messages protected using keys derived from a [\[sender\]](#)_handshake_traffic_secret.
- [] Indicates messages protected using keys derived from [\[sender\]](#)_application_traffic_secret_N.

Security Communications – TLS Handshake

Previous versions of handshake in TLS

- More time to establish the handshake
- Included legacy encryption algorithms (e.g., not performing authentication)



Security Communications – TLS versions

TLS has many versions:

- v1.3 is the most current and the one that should be used (more secure)
- v1.2 is acceptable but migration to 1.3 is better (performance and security reasons)
- v1.1 is not recommended it is deprecated, uses algorithms that are not safe



TLS with Instagram

Let's use OpenSSL to connect to TLS

▪ `openssl s_client -connect instagram.com:443 -msg -msgfile test.txt`

Client

>>> TLS 1.0, RecordHeader [length 0005]
>>> TLS 1.3, Handshake [length 0605], **ClientHello**

**Server
(Instagram.com)**

<<< TLS 1.2, RecordHeader [length 0005]
<<< TLS 1.3, Handshake [length 04ba], **ServerHello**
<<< TLS 1.2, RecordHeader [length 0005]
<<< TLS 1.3, ChangeCipherSpec [length 0001]
<<< TLS 1.2, RecordHeader [length 0005]
<<< TLS 1.3, InnerContent [length 0001]
<<< TLS 1.3, Handshake [length 0006], EncryptedExtensions
<<< TLS 1.2, RecordHeader [length 0005]
<<< TLS 1.3, InnerContent [length 0001]
<<< TLS 1.2, RecordHeader [length 0005]
<<< TLS 1.3, InnerContent [length 0001]
<<< TLS 1.3, Handshake [length 0b48], Certificate
<<< TLS 1.3, Handshake [length 004e], CertificateVerify
<<< TLS 1.3, Handshake [length 0024], Finished

>>> TLS 1.2, RecordHeader [length 0005]
>>> TLS 1.3, ChangeCipherSpec [length 0001]
>>> TLS 1.2, RecordHeader [length 0005]
>>> TLS 1.2, InnerContent [length 0001]
>>> TLS 1.3, **Handshake** [length 0024], Finished

<<< TLS 1.2, RecordHeader [length 0005]
<<< TLS 1.3, InnerContent [length 0001]
<<< TLS 1.3, **Handshake** [length 009c], NewSessionTicket

References

- Schatz, D., Bashroush, R., & Wall, J. (2017). Towards a More Representative Definition of Cyber Security. Journal of Digital Forensics, Security and Law, 12(2). <https://doi.org/10.15394/jdfsl.2017.1476>
- Lawrence Gordon and Martin Loeb, “Managing Cybersecurity Resources: A Cost-Benefit Analysis”, McGraw-Hill
- Ross Anderson, “Security Engineering”, Wiley, online: <http://www.cl.cam.ac.uk/~rja14/book.html>
- Ross Anderson, Rainer Böhme, Richard Clayton, Tyler Moore, “Security Economics and the Internal Market”, ENISA, 2008
- Charles P. Pfleeger, Shari L. Pfleeger, Jonathan Margulies, “Security in Computing”, Prentice Hall, 2015
- Shimon K. Modi, “Biometrics in Identity Management: Concepts to Applications”, Artech House 2011
- William Stallings, Lawrie Brown, “Computer Security: Principles and Practice”, Pearson 2014
- Howard, M.; Pincus, J.; and Wing, J. “Measuring Relative Attack Surfaces.” Workshop on Advanced Developments in Software and Systems Security, 2003.

Question & Comments

?!